Práctica 1: Recogida de información pasiva

Técnicas de Hacking - Universidad Europea

Estudiante: Gonzalo Revuelta
Objetivo: Repsol S.A.

Índice

1. Introducción **2**

2. Perfilado de la Empresa (Footprinting) **2**

3. Análisis de Infraestructura (DNS) **2**

3.1. Teoría y Mapeo Pasivo 2

3.2. Hallazgos DNS 2

4. Inteligencia de Fuentes Abiertas (OSINT) **3**

4.1. Relaciones y Superficie de Ataque 3

4.2. Fugas de Información con Google Dorking 4

5. Conclusiones **5**

Bibliografía **6**

1. Introducción

Como hemos visto en las sesiones de clase, el reconocimiento pasivo es la fase inicial y más crítica de cualquier auditoría. El objetivo es obtener la máxima inteligencia sin tocar directamente los servidores de la víctima, evitando así levantar sospechas en sus sistemas de detección (IDS/IPS).

2. Perfilado de la Empresa (Footprinting)

La investigación comenzó con una pregunta fundamental: ¿Quién es nuestro objetivo? Antes de lanzar herramientas técnicas, necesitaba comprender a Repsol S.A. a nivel de negocio.

Al investigar en fuentes públicas, perfilé que no solo es una empresa energética del IBEX 35, sino una corporación en plena transición digital. Sus clientes abarcan desde usuarios particulares hasta aviación e industria, y sus proveedores tecnológicos clave incluyen a gigantes como Microsoft Azure y AWS. Esta información, puramente OSINT (Glassman & Kang, 2012), es vital: me indica que su «superficie de ataque» no está en un solo edificio, sino distribuida en la nube.

3. Análisis de Infraestructura (DNS)

Una vez entendido el negocio, el siguiente paso lógico fue descubrir cómo se traducen sus nombres de dominio en máquinas reales. El sistema DNS es un pilar fundamental en ciberseguridad, ya que una mala configuración puede revelar toda la topología interna (Petersen & Stowe, 2020).

3.1. Teoría y Mapeo Pasivo

Repasé los registros críticos: A y AAAA (IPs IPv4 e IPv6), CNAME (alias), NS (servidores de nombres), SOA (autoridad), PTR (inversa), MX (correo) y TXT (políticas de seguridad).

Para mantener la pasividad, utilicé **DNSDumpster**. Adicionalmente, quise corroborar los datos desde mi terminal usando `dig`. Para mantener el anonimato, ejecuté la consulta contra el servidor DNS de Google (`dig repsol.com MX @8.8.8.8`). Al consultar a un tercero, garantizo que mi IP no quede registrada en los logs de la compañía objetivo.

3.2. Hallazgos DNS

El análisis reveló que Repsol ha delegado su infraestructura de correo a Microsoft (Office 365). Esto es un descubrimiento crítico para futuros vectores de **phishing**.

Host	IP	ASN	ASN Name	Open Services (from DB)	RevIP
repsol-com.mail.protection.outlook.com	52.101.73.1 mail-am3pr04cu00501.inbound.protection.outlook.com	ASN: 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation The Netherlands		56452
repsol-com.mail.protection.outlook.com	52.101.68.36 mail-db5pr02cu00104.inbound.protection.outlook.com	ASN: 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation Ireland		56504
repsol-com.mail.protection.outlook.com	52.101.68.39 mail-db7pr03cu00607.inbound.protection.outlook.com	ASN: 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation Ireland		56385
repsol-com.mail.protection.outlook.com	52.101.73.15	ASN: 8075 52.96.0.0/12	MICROSOFT-CORP-MSN-AS-BLOCK - Microsoft Corporation The Netherlands		56280

Figura 1: Evidencia de registros MX apuntando a la infraestructura de Microsoft.

4. Inteligencia de Fuentes Abiertas (OSINT)

Sabiendo que su infraestructura técnica está externalizada, decidí buscar fallos de configuración humanos mediante OSINT avanzado.

4.1. Relaciones y Superficie de Ataque

Generé un mapa topológico de sus subdominios. Esto me permitió visualizar la inmensa red de portales que Repsol tiene expuestos a Internet.

Figura 2: Grafo de relaciones de subdominios, ilustrando la dispersión de activos en la red.

4.2. Fugas de Información con Google Dorking

Utilicé operadores avanzados de búsqueda. Como señala (Long et al., 2011), esta técnica es completamente pasiva porque interrogamos a la caché de Google. Diseñé tres estrategias clave:

1. Búsqueda de documentos confidenciales (`filetype:pdf`): El objetivo era encontrar manuales internos que expongan el lenguaje corporativo.

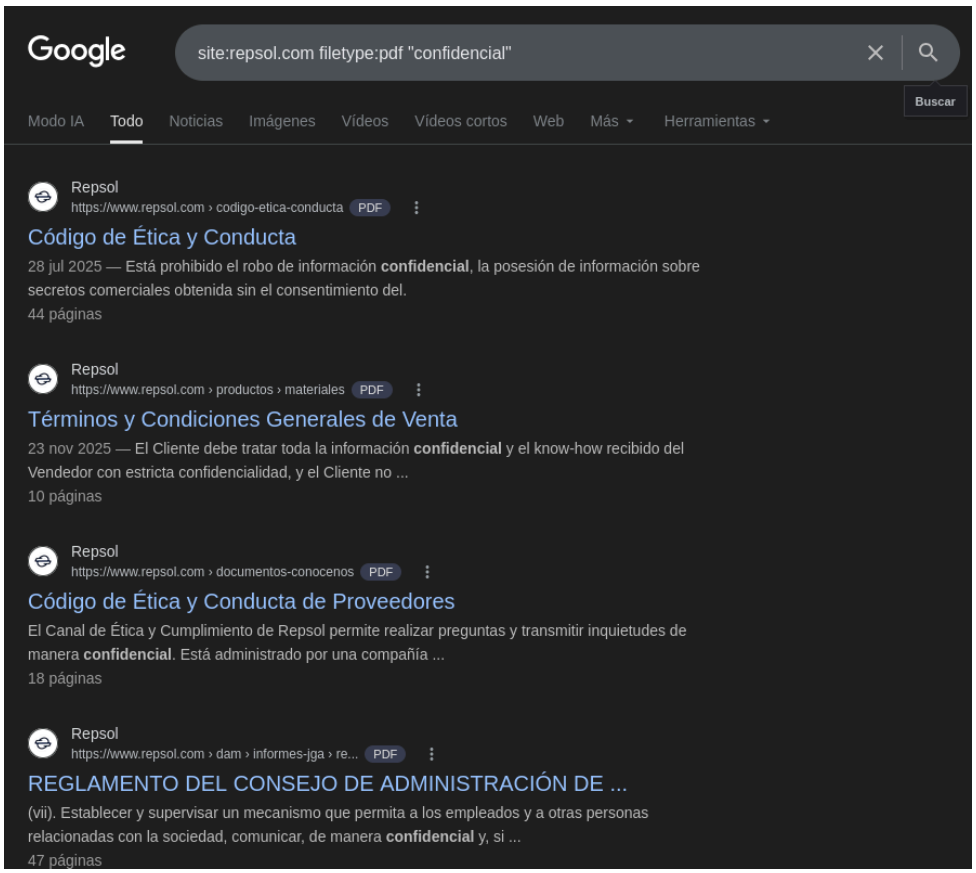

Figura 3: Dork 1: Localización de archivos PDF de carácter sensible e interno.

2. Búsqueda de portales de acceso (`inurl:login`): El objetivo era localizar paneles de administración expuestos al público.

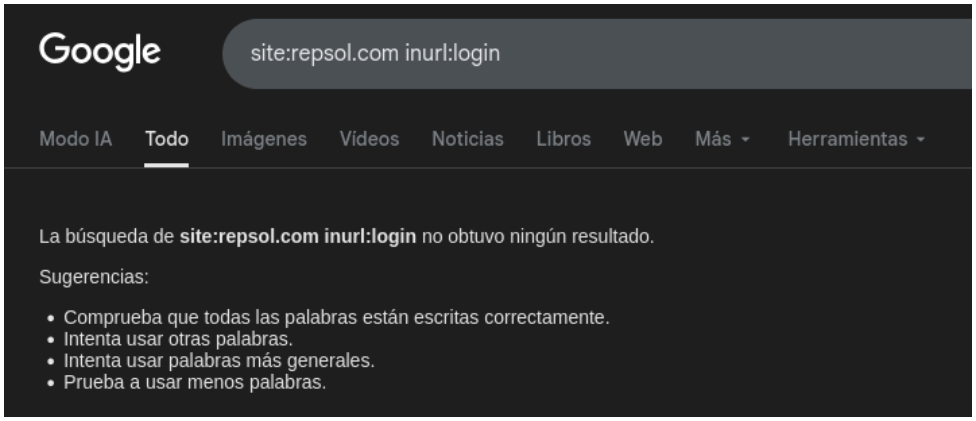

Figura 4: Dork 2: Búsqueda de paneles de autenticación de empleados.

3. Búsqueda de directorios expuestos (`intitle:"index of"`): El objetivo era verificar si los servidores web tienen listados de directorios sin protección.

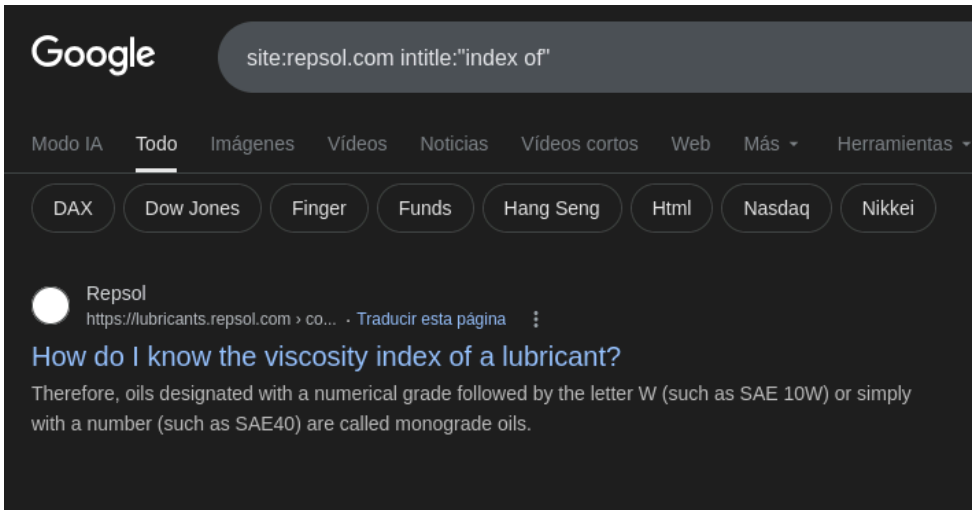

Figura 5: Dork 3: Búsqueda de configuraciones deficientes en servidores web.

5. Conclusiones

La investigación demuestra que el reconocimiento pasivo es increíblemente poderoso. Siguiendo el hilo desde el modelo de negocio, pasando por la infraestructura (DNS), hasta llegar al error humano (OSINT y Dorking), he podido trazar un mapa completo de Repsol S.A. sin enviar un solo paquete malicioso a sus servidores.

Bibliografía

Glassman, A., & Kang, M. (2012). Open source intelligence methods and tools. *Journal of US Intelligence Studies.*

Long, J., Gardner, B., & Brown, J. (2011). *Google hacking for penetration testers*. Elsevier.

Petersen, A. L., & Stowe, G. (2020). *DNS Security: Defending the Domain Name System*. O'Reilly Media.